HTTP Observatory Report

Report Feedback

Scan summary: keeply.work

C

Score: 55 / 100
Scan Time: Just now
Tests Passed: 7 / 10

Scan results

Scoring

Test	Score	Reason	Recommendat
Content Security Policy (CSP)	-20 ✗	Content Security Policy (CSP) implemented unsafely. This includes `'unsafe-inline'` or `data:` inside `script-src`, overly broad sources such as `https:` inside `object-src` or `script-src`, or not restricting the sources for `object-src` or `script-src`.	Remove `unsafe-inline` and `script-src`, overly broad s `object-src` and `script-sr` `object-src` and `script-sr`
Cookies	-	No cookies detected	None
Cross Origin Resource Sharing (CORS)	0 ✓	Content is not visible via cross-origin resource sharing (CORS) files or headers.	None
Redirection	0 ✓	Initial redirection is to HTTPS on same host, final destination is HTTPS	None
Referrer Policy	0* ✓	`Referrer-Policy` header set to `no-referrer`, `same-origin`, `strict-origin` or `strict-origin-when-cross-origin`.	None
Strict Transport Security (HSTS)	0 ✓	`Strict-Transport-Security` header set to a minimum of six months (15768000).	Consider preloading: this re the `preload` and `includeSu` directives and setting `max-a` `31536000` (1 year), and subm to https://hstspreload.org/.

Test	Score	Reason	Recommendat
Subresource Integrity	0* ✓	Subresource Integrity (SRI) is implemented and all scripts are loaded from a similar origin.	None
X-Content-Type-Options	−5 ✗	`X-Content-Type-Options` header not implemented.	Set to `nosniff`.
X-Frame-Options	−20 ✗	`X-Frame-Options` (XFO) header not implemented.	Implement frame-ancestors
Cross Origin Resource Policy	-	Cross Origin Resource Policy (CORP) is not implemented (defaults to `cross-origin`).	None

* Normally awards bonus points, however, in this case they are not included in the overall score (find out why).

CSP analysis

✗ Content Security Policy (CSP) implemented unsafely. This includes `'unsafe-inline'` or `data:` inside `script-src`, overly broad sources such as `https:` inside `object-src` or `script-src`, or not restricting the sources for `object-src` or `script-src`.

Test	Result	Info
Blocks execution of inline JavaScript by not allowing `'unsafe-inline'` inside `script-src`	✗	Blocking the execution of inline JavaScript prov strongest protection against cross-site scriptin Moving JavaScript to external files can also he site more maintainable.
Blocks execution of JavaScript's `eval()` function by not allowing `'unsafe-eval'` inside `script-src`	✓	Blocking the use of JavaScript's `eval()` functic prevent the execution of untrusted code.
Blocks execution of plug-ins, using `object-src` restrictions	✓	Blocking the execution of plug-ins via `object-s` as inherited from `default-src` can prevent atta loading Flash or Java in the context of your pag
Blocks inline styles by not allowing `'unsafe-inline'` inside `style-src`	✗	Blocking inline styles can help prevent attacker modifying the contents or appearance of your p styles to external stylesheets can also help ma more maintainable.
Blocks loading of active content over HTTP or FTP	✓	Loading JavaScript or plugins can allow a man to execute arbitrary code or your website. Rest policy and changing links to HTTPS can help pr

Test	Result	Info
Blocks loading of passive content over HTTP or FTP	✓	This site's Content Security Policy allows the lo passive content such as images or videos over protocols such as HTTP or FTP. Consider chan load them over HTTPS.
Clickjacking protection, using `frame-ancestors`	✗	The use of CSP's `frame-ancestors` directive of grained control over who can frame your site.
Deny by default, using `default-src 'none'`	✗	Denying by default using `default-src 'none'` your Content Security Policy doesn't allow the resources you didn't intend to allow.
Restricts use of the `<base>` tag by using `base-uri 'none'`, `base-uri 'self'`, or specific origins.	✓	The `<base>` tag can be used to trick your site in scripts from untrusted origins.
Restricts where `<form>` contents may be submitted by using `form-action 'none'`, `form-action 'self'`, or specific URIs	✓	Malicious JavaScript or content injection could sensitive form data is submitted to or create ad for data exfiltration.
Uses CSP3's `'strict-dynamic'` directive to allow dynamic script loading (optional)	-	`'strict-dynamic'` lets you use a JavaScript sh load all your site's JavaScript dynamically, with track `script-src` origins.

Cookies

No cookies detected

Raw server headers

Header	Value
Age	0
Via	1.1 varnish
Date	Fri, 24 Apr 2026 12:47:19 GMT
Etag	W/"69eb0773-d14e"
Vary	Accept-Encoding
Server	GitHub.com
Expires	Fri, 24 Apr 2026 12:57:19 GMT
X-Cache	MISS

Header	Value
X-Timer	S1777034840.648455,VS0,VE84
Connection	close
X-Served-By	cache-bfi-kbfi7400052-BFI
Content-Type	text/html; charset=utf-8
X-Cache-Hits	0
Accept-Ranges	bytes
Cache-Control	max-age=600
Last-Modified	Fri, 24 Apr 2026 06:02:27 GMT
X-Proxy-Cache	MISS
Content-Length	14116
X-Fastly-Request-Id	20b5c8bb34bdf66a9c4c08aeea56777dcccac500
X-Github-Request-Id	C13C:1C039A:27C1050:28B33F7:69EB6656
Strict-Transport-Security	max-age=31556952
Access-Control-Allow-Origin	*

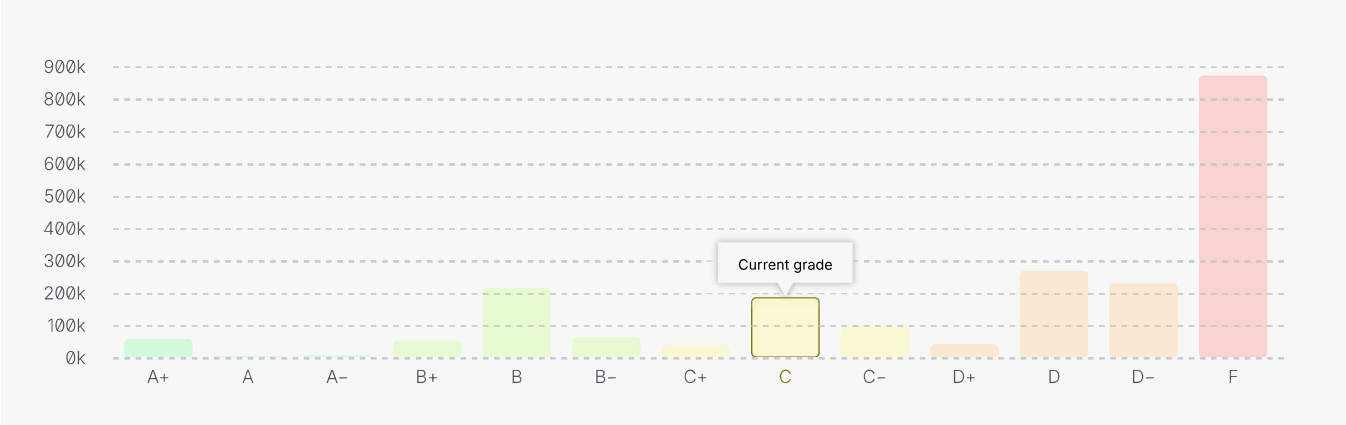
Scan history

Changes in score over time

Date	Score	
2026年4月24日 晚上8:47:19	55	C

Benchmark comparison

Performance trends from the past year



Refer to this graph to assess the website's current status. By following the recommendations provided and rescanning, you can expect an improvement in the website's grade.

mdn_

Your blueprint for a better internet.